

Acme Corp

Access Control Policy

Version 3.1 | Effective: January 15, 2025

Classification: Internal / Confidential

This document is the property of Acme Corp and is intended for internal use only. Unauthorized distribution, reproduction, or disclosure is strictly prohibited. This policy has been approved by the Chief Information Security Officer (CISO) and is effective as of the date indicated above.

1 Purpose and Scope

This policy establishes the requirements for managing access to Acme Corp information systems, applications, and data assets. It applies to all employees, contractors, temporary workers, and third-party service providers who require access to Acme Corp systems and the Cardholder Data Environment (CDE). The objective is to ensure that access is granted on a need-to-know and least-privilege basis, and that all access is properly authorized, authenticated, and auditable.

2 User Identification and Authentication

2.1 Unique User Identification

All users must be assigned a unique user ID before they are allowed access to any system component or cardholder data. Generic, shared, or group IDs are strictly prohibited for standard operations. Each user ID must be traceable to an individual person. In cases where shared accounts are technically unavoidable (e.g., certain legacy systems), compensating controls including enhanced logging and dual-authorization must be implemented and documented.

2.2 Multi-Factor Authentication (MFA)

Multi-factor authentication is required for all remote access to the corporate network and for all access to the Cardholder Data Environment (CDE). MFA must use at least two of the following factors: something the user knows (password or passphrase), something the user has (smart card, hardware token, or authenticator app), or something the user is (biometric verification). MFA tokens must not be shared between users. Service provider personnel with remote access to customer premises must also use unique MFA credentials per customer.

2.3 Password Requirements

All system and application passwords must meet the following minimum requirements: minimum length of 12 characters, inclusion of numeric and alphabetic characters, passwords must be changed at least every 90 days, new passwords must not match any of the last four passwords used, first-time or reset passwords must be unique to each user and changed upon first use. Default vendor-supplied passwords on all system components must be changed before deployment to production.

3 Access Authorization and Role Management

3.1 Role-Based Access Control (RBAC)

Access rights must be assigned based on job classification and function, following the principle of least privilege. Access control systems must default to deny-all and restrict access to the minimum necessary for business functions. All access permissions must be documented in an access control matrix that maps roles to specific system privileges. The Human Resources department must notify IT Security of all role changes within 24 hours of the change.

3.2 Privileged Access Management

Administrative and privileged access must be restricted to personnel whose job duties specifically require such access. Privileged accounts must use separate credentials from standard user accounts. All privileged access sessions must be logged and monitored. Privileged access must be reviewed quarterly by the Information Security team. Privileged

accounts must not be used for routine daily activities such as email or web browsing.

4 Periodic Access Reviews

User access rights must be reviewed at least every six months to verify that access remains appropriate for the user's current role. Access review must be conducted by system owners in coordination with the Information Security team. Results of access reviews must be documented and retained for a minimum of twelve months. Any discrepancies identified during access reviews must be remediated within 30 calendar days.

5 Access Revocation and Termination

Upon termination of employment, all logical and physical access must be revoked immediately. The Human Resources department must notify IT Security within four hours of any termination. All authentication tokens, badges, keys, and company equipment must be collected and documented before the employee departs the premises. For voluntary departures, access must be revoked no later than the last day of employment. Accounts belonging to terminated users must be disabled and retained in a dormant state for 90 days for forensic purposes before deletion.

6 Audit Logging and Monitoring

All access to system components and cardholder data must be logged. Audit logs must capture: user identification, type of event, date and time, success or failure indication, origination of event, and identity or name of affected data, system component, or resource. Audit trails must be retained for a minimum of twelve months, with at least three months immediately available for analysis. Automated alerts must be configured for suspicious activity such as repeated failed login attempts, privilege escalation, and access from unusual locations.